

△△△△△△ 상임감사

개선

제 목	공단 정보보안 업무지침 개정 필요
소 관 기 관	△△△△△
조 치 기 관	△△△△△
조 치 기 한	처분(요구)일로부터 6개월 이내
내 용	

1. 업무개요

공단은 국가정보원의 「국가 정보보안 기본지침」 및 「환경부 정보보안 업무지침」에 따라 △△△△△△(이하 ‘공단’이라 한다)이 수행하여야 할 정보보안과 관련한 구체적 사항을 정하기 위하여 자체 「정보보안 업무지침」을 제정·운영 중에 있다.

2. 관계법령 및 판단기준

「환경부 정보보안 업무지침」은 국가정보원의 「국가 정보보안 기본지침」 개정(‘23. 1. 31.)에 따라 각급기관의 장이 민간클라우드 컴퓨팅서비스 이용시 준수해야 할 보안대책 등을 반영하여 2023년 3월에 일부 개정하는 등 보안대책을 강화하였다.

3. 감사결과 확인된 문제점

[표1] 공단 정보시스템 클라우드 환경 이용 현황

연번	부서	시스템명	도입시기
1	△△△△△	△△△△△	2021
2	△△△△△△△	△△△△ △△△△△△△	2021
3	△△△△△	△△△△△△△	2022
4	△△△△△	△△ △△△△ △△△ △△△	2022
5	△△△△△	△△△ △△△△△△△	2021
6	△△△△△	△△△△ △△ △△△△	2021
7	△△△△△	△△△△ △△△△△ △	2021

공단은 「환경부 정보보안 업무지침」 제7조(정보보안내규)에 따라 공단이 수행하여야 할 정보보안과 관련한 구체적 사항을 정하기 위하여 자체 「정보보안 업무지침」을 제정·운영하고 있으며,

정보화 기술 및 IT발전 고도화로 공단 내 정보시스템 또한 정보보안 강화를 위해 클라우드 환경(△△△△ △△△△△△△, △△△△△ 등 △건)으로 다수 이전하고 있으나,

현행 「정보보안 업무지침」의 경우 상위기관(국가정보원, 환경부) 지침에 개정된 “클라우드컴퓨팅”과 “공공클라우드센터” 용어의 정의와 이에 대한 세부 보안대책사항 등의 내용이 반영되어 있지 않아 클라우드컴퓨팅 이용에 따른 체계적인 관리방안이 미흡한 실정이다.

이에, △△△△△은 클라우드 도입에 따른 정보시스템 보안관리 강화를 위해 클라우드 컴퓨팅 관리 및 기술적 가이드라인이 보완될 수 있도록 관련 내용을 반영하여 공단 「정보보안 업무지침」을 개정할 필요성이 있다.

[표2] 공단 정보보안 업무지침 검토 필요 사항 목록

현행('21. 8. 개정)	환경부 정보보안 기본지침('23. 3. 일부개정) 준용 반영검토 사항
제2조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.	제2조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.
30. <신설>	30. “클라우드컴퓨팅(Cloud Computing)”이란 직접·
	공유된 정보통신기기, 정보통신설비, 소프트웨어 등 정보통신자원을 이용자의 요구나 수요변화에 따른 정보통신망을 통하여 신축적으로 이용할 수 있도록 하는 정보처리체계를 말한다.
31. <신설>	31. 공공클라우드센터란 외교·안보, 수사·재판, 행정업무 처리 등 정보시스템을 통합관리하기 위해 각급기관 등의 장이 설치·운영중인 데이터센터를 말한다.
제37조(클라우드컴퓨팅 보안)	제37조(클라우드컴퓨팅 보안)
① 이사장은 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제12조에 따라 클라우드컴퓨팅을 자체 구축·운영하고자 할 경우 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안가이드라인」에 명시된 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 보안대책을 수립·시행하여야 한다.	① 이사장은 클라우드컴퓨팅(공공 클라우드 센터를 포함)을 자체 구축·운영하고자 할 경우, 국가정보원장이 배포한 「국가 클라우드 컴퓨팅 보안 가이드라인」에 명시된 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 보안대책을 수립·시행하여야 한다.
② 이사장은 민간 클라우드컴퓨팅서비스를 이용하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.	② 이사장은 민간 클라우드컴퓨팅서비스를 이용하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.
1. 국내에 위치한 정보시스템에 데이터가 저장되는 서비스로서 일반 이용자용 서비스 영역과 물리적으로 분리되어 제공되는 서비스 영역(이하 “공공 전용(專用) 클라우드”라 한다)에 한하여 활용	1. 국내에 위치한 정보시스템(인증서버, 로그 및 백업서버 등)·관리주체에 의해 데이터가 저장·관리되는 서비스의 이용
2. 과학기술정보통신부장관이 고시한 「클라우드컴퓨팅 서비스 정보보호에 관한 기준」에 부합하는 서비스 선정	2. 다음 각목의 요건에 따라 일반 이용자용 서비스와 영역이 분리되어 제공되는 서비스(이하 “공공 전용(專用) 민간클라우드”라 한다)의 이용
가. <신설>	가. 영역 분리는 일반 이용자용 서비스와 데이터 및

<u>나. <신설></u> <u>다. <신설></u> 3. 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안 가이드라인」에서 제시하는 민간 클라우드컴퓨팅 서비스 이용 보안기준 및 행정안전부장관이 배포한 「행정·공공기관 민간 클라우드 이용 가이드라인」에 따른 절차 이행 <u>4. <신설></u> <u>5. <신설></u> ③ ~ ⑤ 생략(변동없음) <u>⑥ <신설></u> <u>⑦ <신설></u> (이하 생략)	<u>프로세스 등의 간섭없이 국가정보원 및 이용기관의 보안관제, 사고조사, 예방보안활동 유지를 위한 제반 환경을 만족해야 함</u> <u>나. 영역 분리는 ‘시스템 중요도’에 따라 물리적 또는 논리적으로 구현</u> <u>다. ‘시스템 중요도’ 분류는 [별표4]의 기준 준용</u> 3. 국가정보원장이 배포한 「국가 클라우드 컴퓨팅 보안 가이드라인」에서 정하는 바에 따라 국가정보원장이 제시하거나 제시 예정인 민간 클라우드컴퓨팅서비스 이용 <u>4. ‘내부망·인터넷망 분리’ 원칙 등 여타 보안 관련사항은 「국가정보보안기본지침」 및 「국가 클라우드 컴퓨팅 보안가이드라인」 준수</u> <u>5. 민간 클라우드컴퓨팅서비스 사업자와 계약시 해킹사고 및 장애 대응, 재발 방지 등에 필요한 조치를 위해 국가정보원 및 이용기관의 보안관제 및 사고조사, 사이버공격 및 위협에 대한 예방 및 대응활동 등에 적극 협조하도록 하는 내용의 명시</u> ③ ~ ⑤ 생략(변동없음) <u>⑥ 제2항에 따라 각급기관이 이용하는 민간 클라우드컴퓨팅 서비스의 제공자는 공공 전용(專用) 민간클라우드 영역에 대해 정부 기관에 준하는 보안관리 책임을 진다.</u> <u>⑦ 교육현장에는 제1항 및 제2항을 적용하지 아니하며, 학교장 책임 하에 자체 구축하거나 민간 클라우드컴퓨팅서비스를 이용할 수 있다.</u>
--	--

4. 관계부서 의견

△△△△△은 2024년 정보보안 관리체계 특정감사 결과를 수용하며, 클라우드 컴퓨팅 관리 및 정보보안 강화를 위해 정보보안 업무지침에 관련 내용 반영을 검토하겠다는 의견을 제시하였다.

조치할 사항

이사장(△△△△△△)은 클라우드 도입에 따른 기술적 가이드라인이 보완
될 수 있도록 공단 「정보보안 업무지침」을 개정하시기 바랍니다.(개선)